Auth0 for AI Agents

(optional pronouns)
Firstname Lastname
Title

(optional pronouns)
Firstname Lastname
Title

(optional pronouns)
Firstname Lastname
Title

© Okta, Inc. and/or its affiliates. All rights reserved.

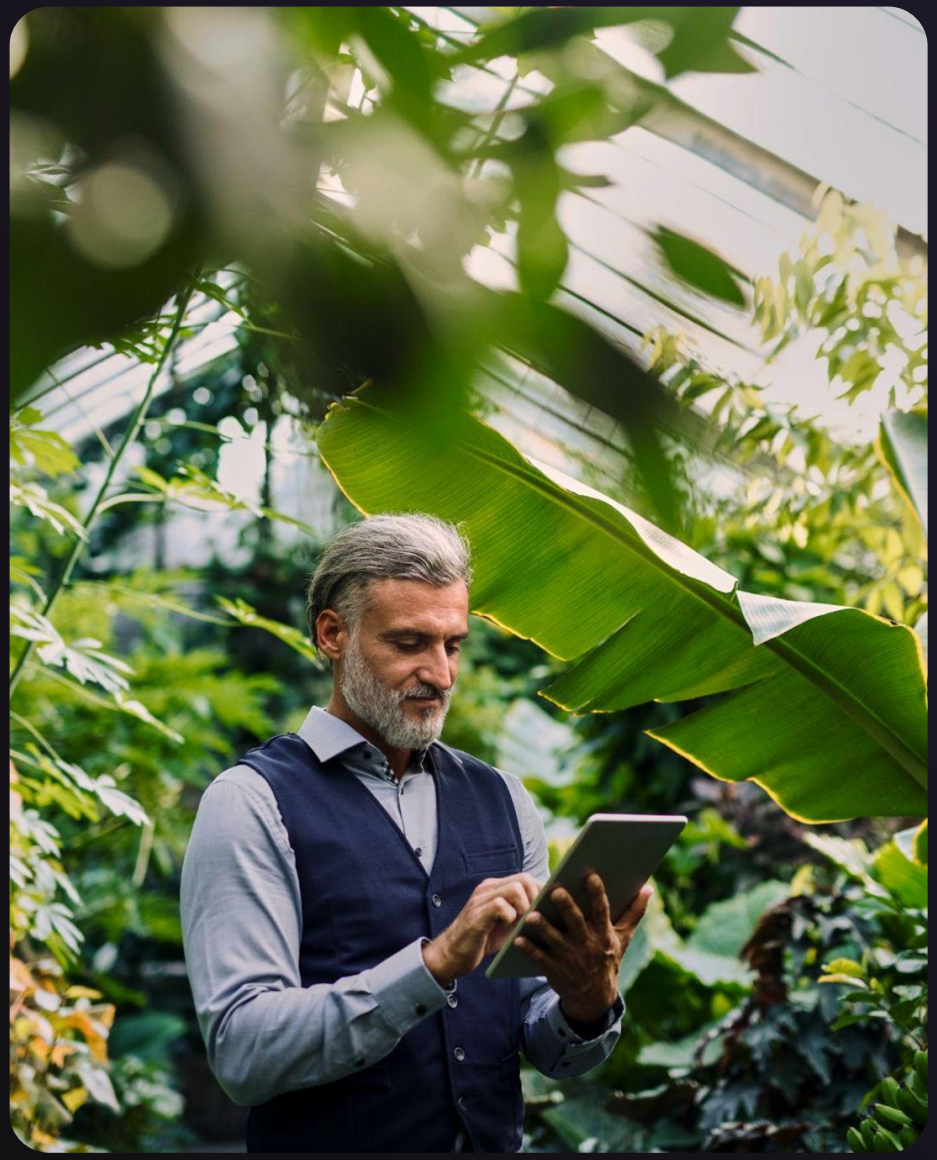
DATA CLASSIFICATION: OKTA, INC. PUBLIC

Safe harbor

This presentation contains "forward-looking statements" within the meaning of the "safe harbor" provisions of the Private Securities Litigation Reform Act of 1995, including but not limited to, statements regarding our financial outlook, business strategy and plans, market trends and market size, opportunities and positioning. These forward-looking statements are based on current expectations, estimates, forecasts and projections. Words such as "expect," "anticipate," "should," "believe," "hope," "target," "project," "goals," "estimate," "potential," "predict," "may," "will," "might," "could," "intend," "shall" and variations of these terms and similar expressions are intended to identify these forward-looking statements, although not all forward-looking statements contain these identifying words. Forward-looking statements are subject to a number of risks and uncertainties, many of which involve factors or circumstances that are beyond our control. For example, global economic conditions have in the past and could in the future reduce demand for our products; we and our third-party service providers have in the past and could in the future experience cybersecurity incidents; we may be unable to manage or sustain the level of growth that our business has experienced in prior periods; our financial resources may not be sufficient to maintain or improve our competitive position; we may be unable to attract new customers, or retain or sell additional products to existing customers; customer growth has slowed in recent periods and could continue to decelerate in the future; we could experience interruptions or performance problems associated with our technology, including a service outage; we and our third-party service providers have failed, or were perceived as having failed, to fully comply with various privacy and security provisions to which we are subject, and similar incidents could occur in the future; we may not achieve expected synergies and efficiencies of operations from recent acquisitions or business combinations, and we may not be able to successfully integrate the companies we acquire; and we may not be able to pay off our convertible senior notes when due. Further information on potential factors that could affect our financial results is included in our most recent Quarterly Report on Form 10-Q and our other filings with the Securities and Exchange Commission. The forward-looking statements included in this presentation represent our views only as of the date of this presentation and we assume no obligation and do not intend to update these forward-looking statements.

Any products, features, functionalities, certifications, authorizations, or attestations referenced in this presentation that are not currently generally available or have not yet been obtained or are not currently maintained may not be delivered or obtained on time or at all. Product roadmaps do not represent a commitment, obligation or promise to deliver any product, feature, functionality, certification or attestation and you should not rely on them to make your purchase decisions.

© Okta, Inc. and/or its affiliates. All rights reserved.
DATA CLASSIFICATION: OKTA, INC. PUBLIC



GenAI is a fundamental shift in software

$100B+
30%+ CAGR

Global generative AI market to reach $100B+ by 2032, growing at 30%+ CAGR

- Fortune Business Insights, 2025

82%

of organizations plan to integrate AI agents by 2026

- Capgemini, 2024

78%

of respondents expect to increase their overall AI spending in the next fiscal year

- Deloitte, 2025

auth0 © Okta, Inc. and/or its affiliates. All rights reserved.

DATA CLASSIFICATION: OKTA, INC. PUBLIC

How are AI Agents changing the way we work?

They aren't just chat bots anymore.

English, and all other **Human Languages** are now **programming languages.**

Eliminate repetitive tasks across multiple applications, even with APIs.

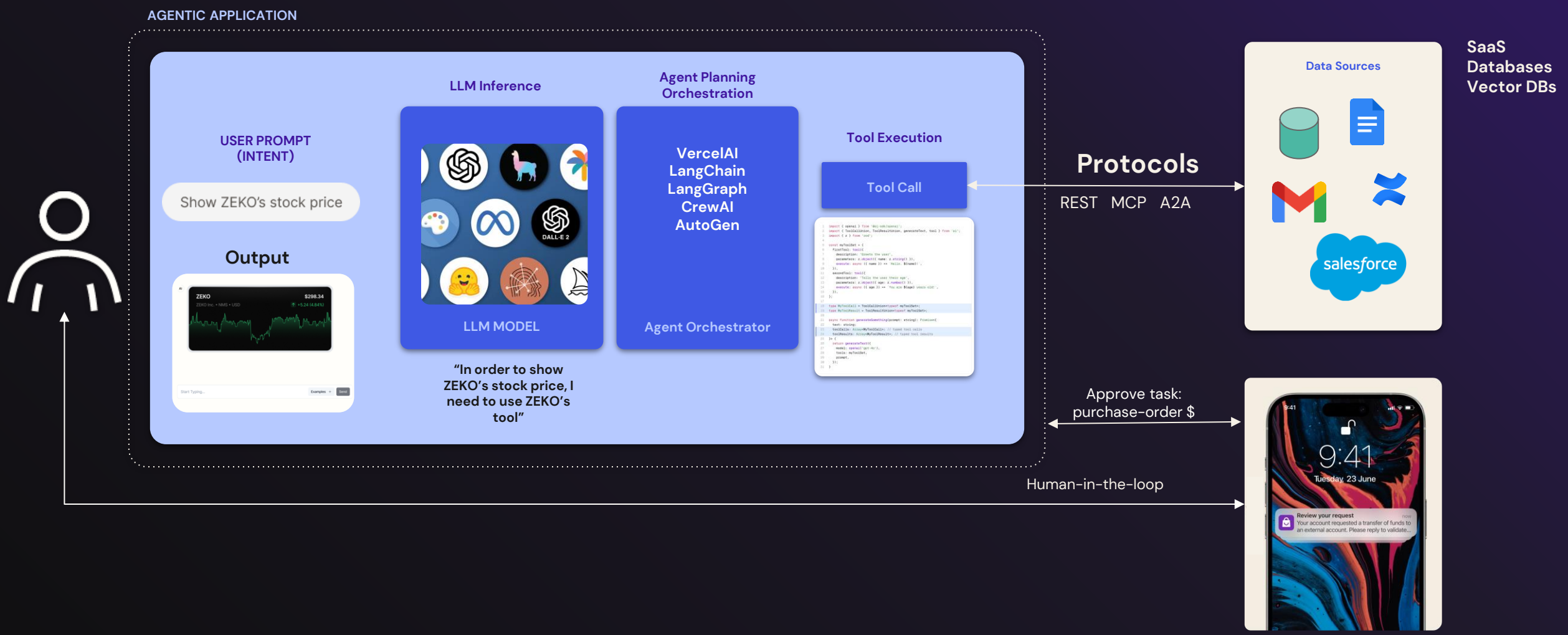
Run autonomously, with little to no user interaction, to wait and work while you are away.

Coordinate multi-step flows with memory and context to complete tasks across tools

© Okta, Inc. and/or its affiliates. All rights reserved.

DATA CLASSIFICATION: OKTA, INC. PUBLIC

GenAI Applications



auth0 © Okta, Inc. and/or its affiliates. All rights reserved.

DATA CLASSIFICATION: OKTA, INC. PUBLIC

What about Security?

Marc Benioff
@Benioff

Amazing. “Organizations are reportedly reluctant to integrate Copilot into their workflow because of the tool's capabilities to bypass critical security measures and access private credentials that would ordinarily require high-level clearance.”

Source x.com Nov/24

David Fowler
@davidfowl

I know we’re talking about how the future is “agentic” but who is solving the security/auth problem? These agents need to have access the systems you have access to (probably with limited permissions) and need to be able to act on your behalf.

Source x.com Dec/24

Alex Albert
@alexalbert__

We just published a near-term development roadmap for the model context protocol (MCP)

Some highlights:
- Remote support (and auth!)
- Reference implementations
- Better package management
- Agent support

Source x.com Jan/25

auth0 © Okta, Inc. and/or its affiliates. All rights reserved.

DATA CLASSIFICATION: OKTA, INC. PUBLIC

Identity is the #1 Attack vector

Over

80%

of breaches involve compromised credentials

Identity threats don't stop at login

Before login

- Bot Attacks

At login

- Account takeover attacks

After login

- Session hijacking
- Suspicious Sessions
- Transaction Tampering

Verizon Data Breach Investigation Report, 2024

auth0 © Okta, Inc. and/or its affiliates. All rights reserved.

DATA CLASSIFICATION: OKTA, INC. PUBLIC

Set the bar for Generative AI

Identity is the foundation for agent adoption in regulated environments.

Identity must be part of your GenAI design from the start.

auth0

© Okta, Inc. and/or its affiliates. All rights reserved.

DATA CLASSIFICATION: OKTA, INC. PUBLIC

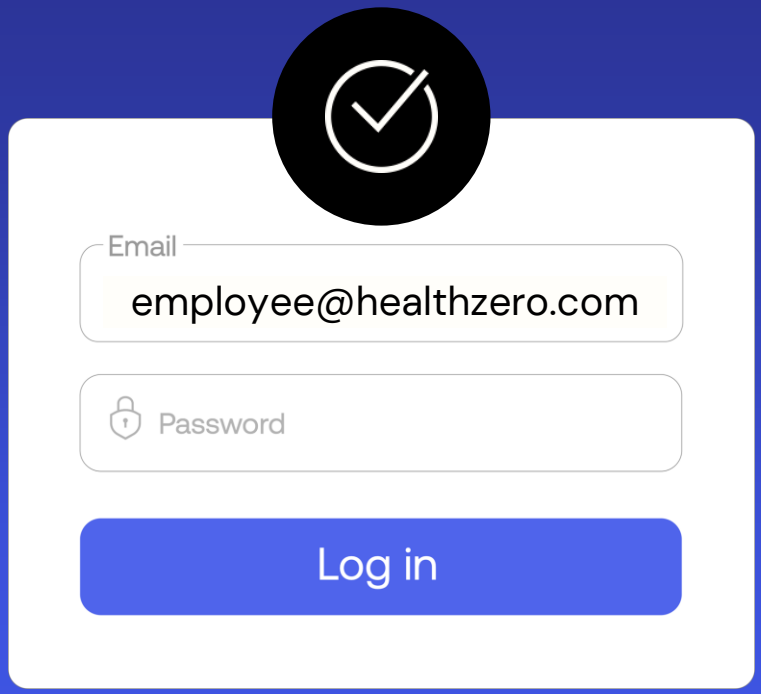
How Identity Powers Secure GenAI Applications

auth0

© Okta, Inc. and/or its affiliates. All rights reserved.

DATA CLASSIFICATION: OKTA, INC. PUBLIC

AI needs to know who I am

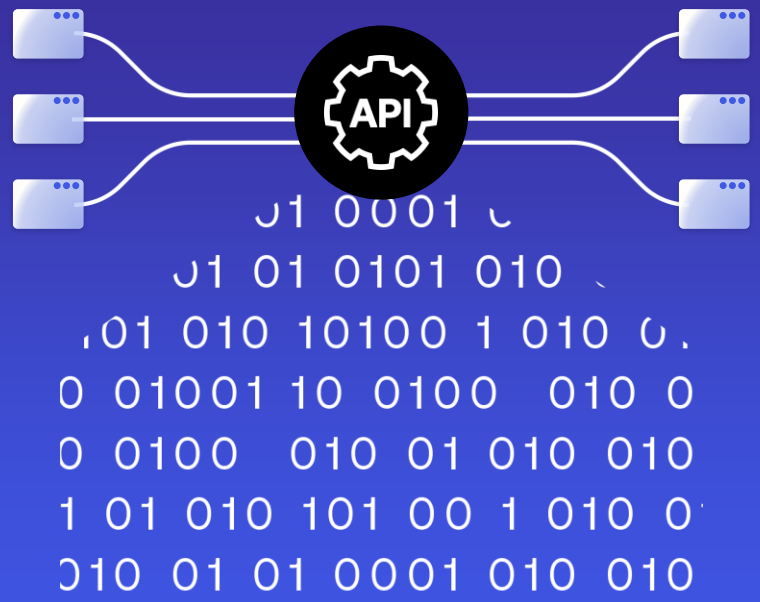


Authentication User Context

auth0 © Okta, Inc. and/or its affiliates. All rights reserved.

DATA CLASSIFICATION: OKTA, INC. PUBLIC

AI needs to call APIs on users behalf



Tokens Tool Access

auth0 © Okta, Inc. and/or its affiliates. All rights reserved.

DATA CLASSIFICATION: OKTA, INC. PUBLIC

AI uses
async
interactions

Consent User Approval

auth0 © Okta, Inc. and/or its affiliates. All rights reserved.

DATA CLASSIFICATION: OKTA, INC. PUBLIC

AI data access must consider user permissions

Fine-grained authorization

RAG

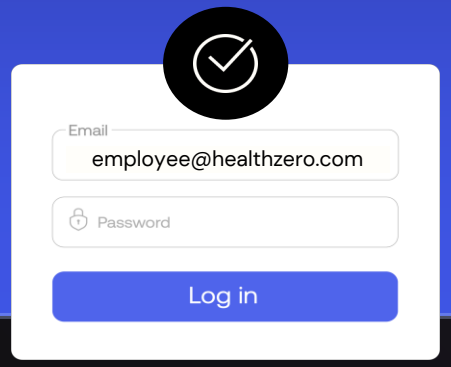
auth0 © Okta, Inc. and/or its affiliates. All rights reserved.

DATA CLASSIFICATION: OKTA, INC. PUBLIC

How Auth0 Powers Secure GenAI Applications

User Authentication

AI needs to
know who I am



Token Vault

AI needs to
call APIs on
users behalf

Async Authorization

AI uses
async interactions

Fine-Grained Authorization

AI data access
must consider
user permissions

Quickstart

SDKs

© Okta, Inc. and/or its affiliates. All rights reserved.

DATA CLASSIFICATION: OKTA, INC. PUBLIC

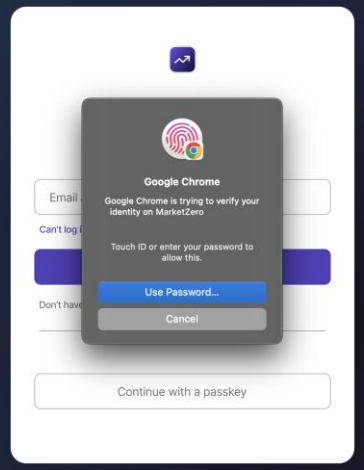
How Auth0 Helps Secure GenAI Applications

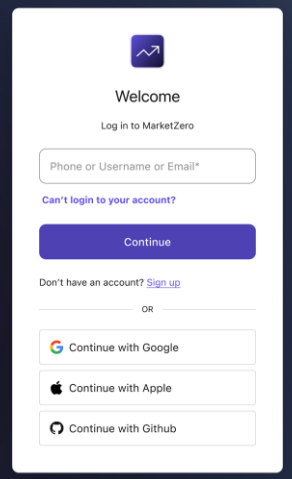
© Okta, Inc. and/or its affiliates. All rights reserved.

User Authentication for modern applications

Support individual users and workspaces with one identity system

Individuals

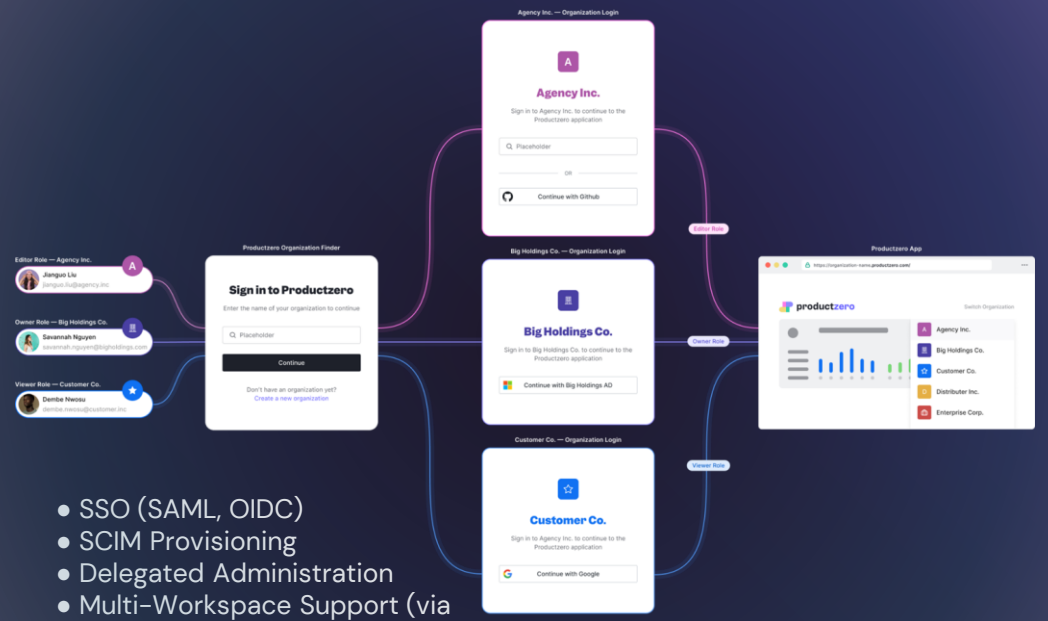




Passwordless Options
- Passkeys
- OTP
- Email

Social Login
Flexible Identifiers

Workspaces



- SSO (SAML, OIDC)
- SCIM Provisioning
- Delegated Administration
- Multi-Workspace Support (via Organizations)

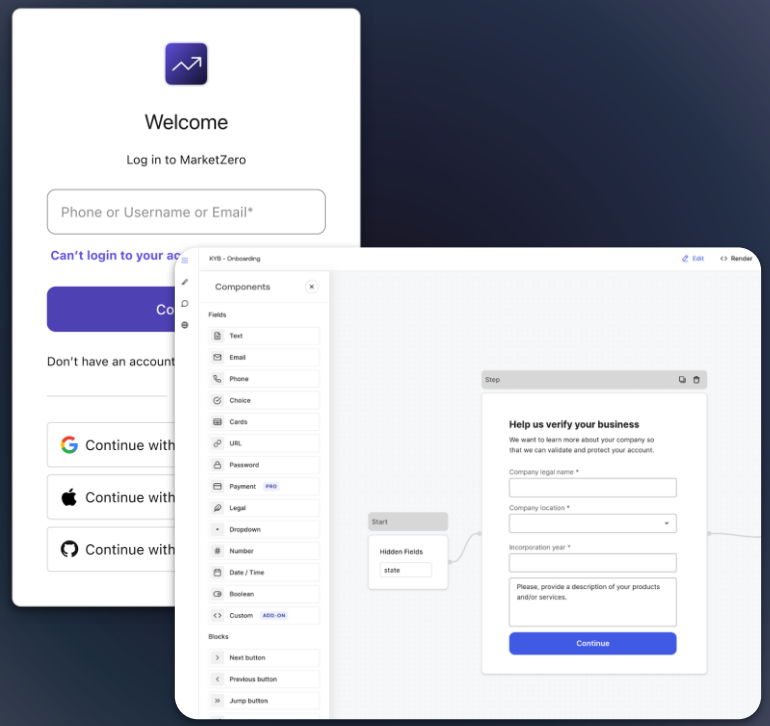
Universal Login · MFA · Bot Protection · Progressive Profiling · Session Management · Full UI Customization

auth0 © Okta, Inc. and/or its affiliates. All rights reserved.

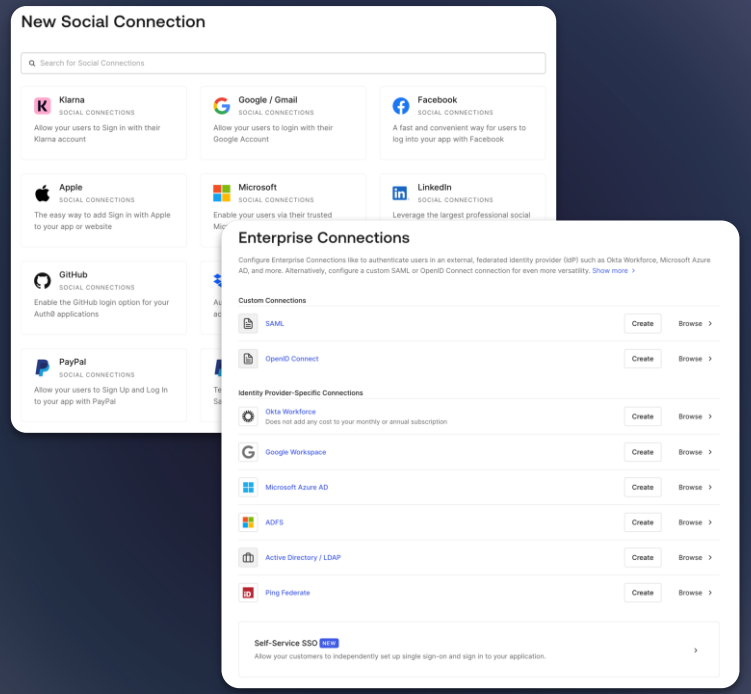
DATA CLASSIFICATION: OKTA, INC. PUBLIC

Customize journeys, connect user identities

User Experience



User Identities



What you unlock

- Unify identities into a single user profile
- Build a 360° view of users
- Integrate identity with your CRM, CDP or back office
- Enrich profiles to deliver personalized experiences
- Customize login flows for every user type

© Okta, Inc. and/or its affiliates. All rights reserved.
DATA CLASSIFICATION: OKTA, INC. PUBLIC

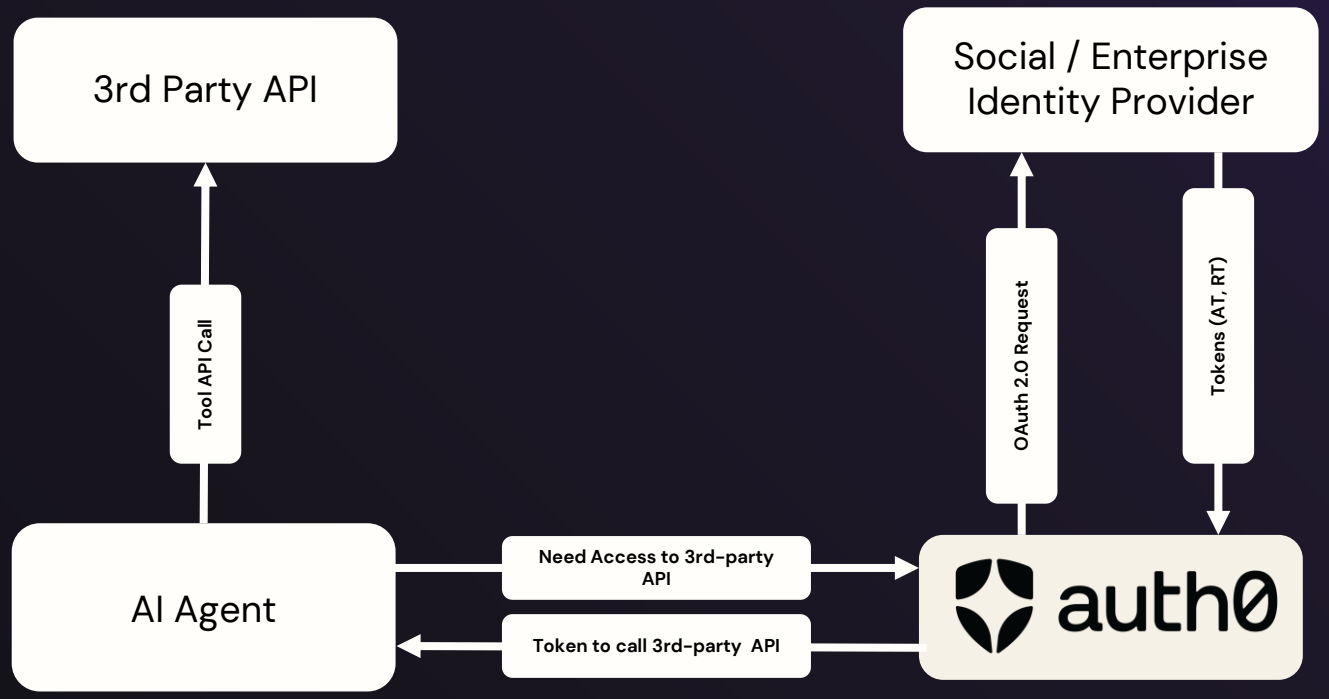
What happens post user authentication?

Tokens enable AI Agents to communicate with tools on behalf of users

Token Management

AI Agent tools use tokens for

- Call 3rd-party APIs like Gmail, Google Calendar, etc
- Act autonomously on behalf of users



Token Exchange

ID & Access Tokens issued

- Traditional OAuth2 flow
- Tokens are scoped and specific for each upstream provider (Google, Apple, Github, etc)
- Tokens are time-limited

Without secure token management, AI agents introduce risk.
Tokens must be stored safely. Token Vaults keep that risk contained.

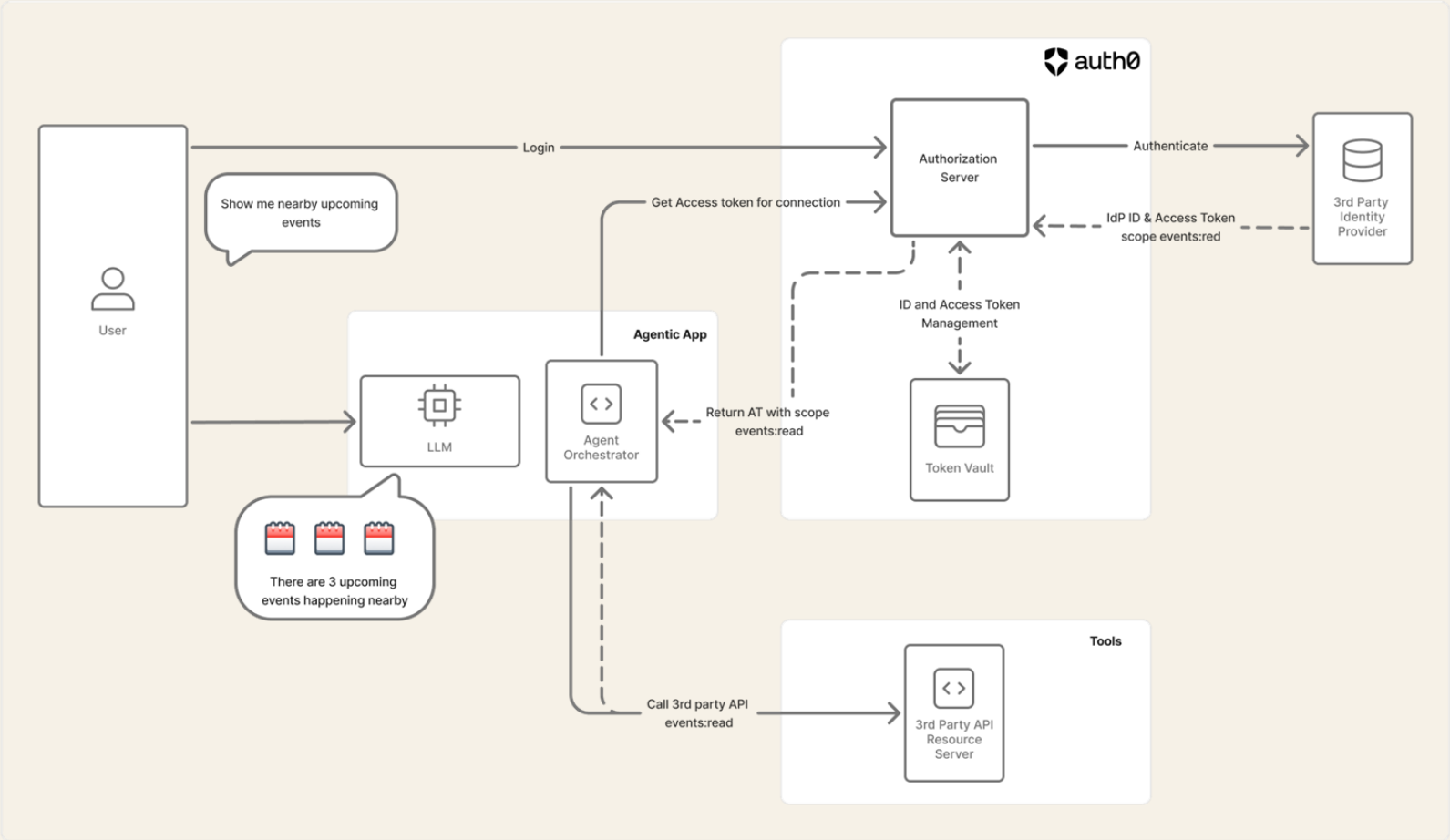
© Okta, Inc. and/or its affiliates. All rights reserved.

DATA CLASSIFICATION: OKTA, INC. PUBLIC

Auth0 Token Vault

Secure, seamless access to third-party APIs **with zero token handling.**

- **Secure Storage**
  Third-party access tokens stored and encrypted within Auth0
- **Federated Token Exchange**: Enable delegated access to Gmail, Slack, GitHub, and other services with user consent
- **Automatic Token Management**: Auth0 handle refresh tokens and exchanges automatically, with no custom OAuth logic required



Built-in security, reduce exposure of long-lived tokens

© Okta, Inc. and/or its affiliates. All rights reserved.
DATA CLASSIFICATION: OKTA, INC. PUBLIC

How to Get Federated Access Tokens from Auth0 Token Vault

Less **code**, Lower maintenance. Secure by design.

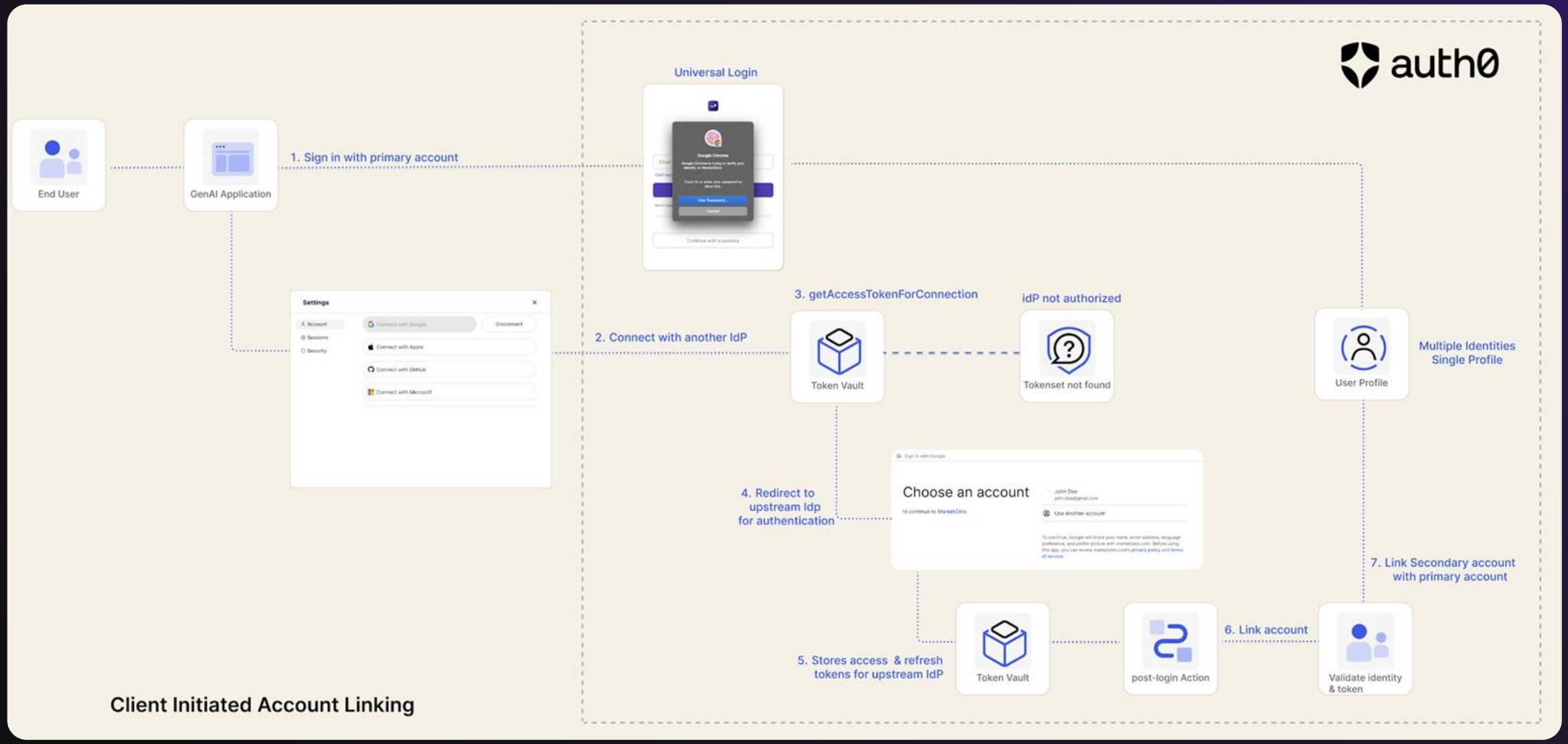
```
import { google } from "googleapis";
import { auth0 } from "./auth0";

export async function getGoogleAuth () {
  // Get access token for Google social connection.
  const { token } = await auth0.getAccessTokenForConnection({ connection: 'google-oauth2' });

  // Create Google OAuth client.
  const googleOAuthClient = new google.auth.OAuth2();
  googleOAuthClient.setCredentials({ access_token: token });

  return googleOAuthClient;
};
```

No manual token handling, no custom refresh logic.

auth0 © Okta, Inc. and/or its affiliates. All rights reserved.

DATA CLASSIFICATION: OKTA, INC. PUBLIC

Client Initiated Account Linking



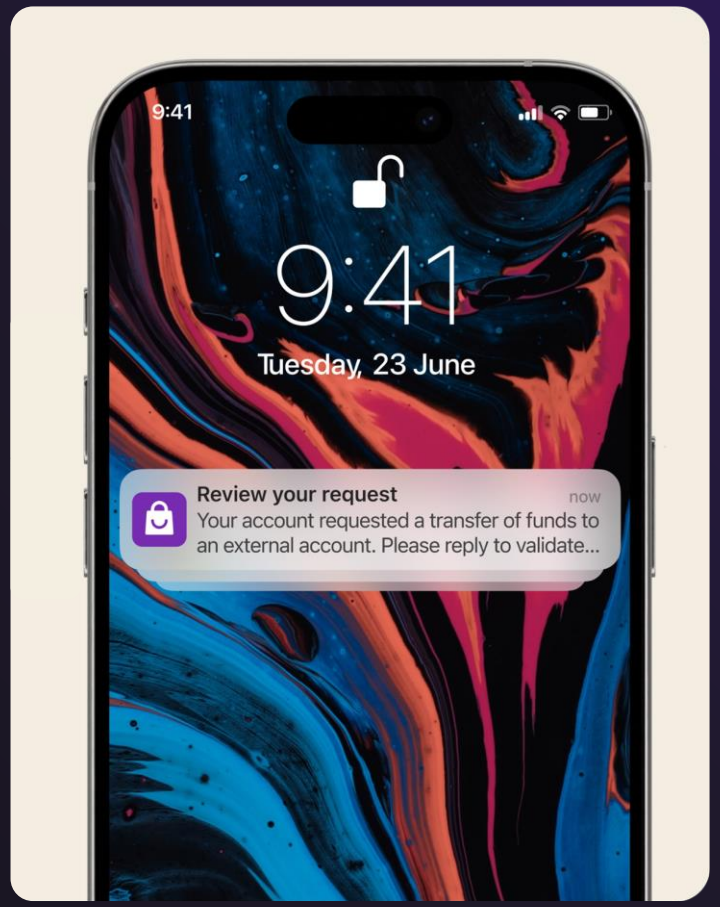
© Okta, Inc. and/or its affiliates. All rights reserved.
DATA CLASSIFICATION: OKTA, INC. PUBLIC

Human-in-the-loop (HITL) framework

Empower AI Agents to request decisions from users, securely.

- Balance between agent autonomy and user control
- Governance model for reviewing sensitive actions
- Let users approve, deny or override agent behavior

- When it's needed
  - Sensitive data access
  - Communication or external actions
  - Workflow escalations



auth0 © Okta, Inc. and/or its affiliates. All rights reserved.

DATA CLASSIFICATION: OKTA, INC. PUBLIC

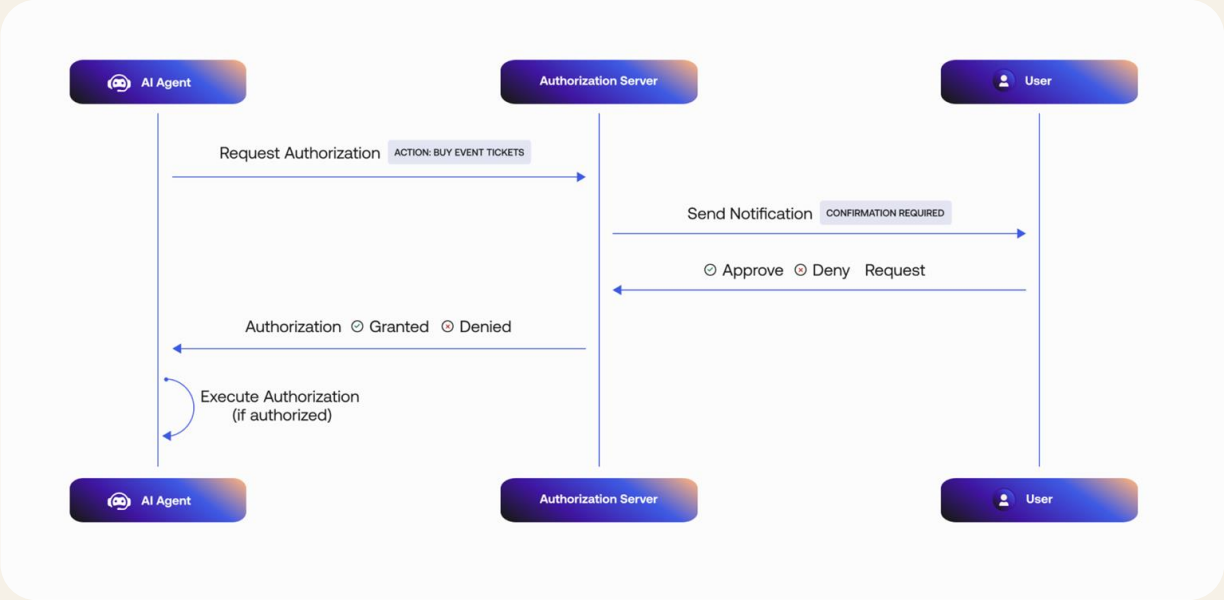
Implement HITL with Asynchronous Authorization

- **Background Execution**
  AI agents run in the background and prompt users only when approvals are needed.

- **Delegated Consent via Client-Initiated Backchannel Authentication Flow (CIBA)**
  Based on OAuth2 CIBA security standards for secure, backchannel approval. AI Agent-initiated, no user redirection needed.

- **Contextual, Input-Rich Consent**
  Supports rich, contextual, fine-grained authorization data based on OAuth2 Rich Authorization Requests (RAR).

- **Event-Driven agent notifications**
  Auth0 uses CIBA ping mode to notify the agent when the user responds. No polling needed. Fallback to a secure link-based approval method.



© Okta, Inc. and/or its affiliates. All rights reserved.

DATA CLASSIFICATION: OKTA, INC. PUBLIC

How to implement Asynchronous Authorization

```
const auth0AI = new Auth0AI();

export const buy = (context: Context) => {
  const withAsyncAuthorization = auth0AI.withAsyncUserConfirmation({
    userID: context.userID,
    bindingMessage: async ({ ticker, qty }) =>
      `Do you want to buy ${qty} shares of ${ticker}`,
    scopes: ["openid", "stock:trade"],
    audience: process.env["AUDIENCE"]!,
    /**
     * When this flag is set to `block`, the execution of the tool awaits
     * until the user approves or rejects the request.
     *
     * Given the asynchronous nature of the CIBA flow, this mode
     * is only useful during development.
     *
     * In practice, the process that is awaiting the user confirmation
     * could crash or timeout before the user approves the request.
     */
    onAuthorizationRequest: "block",
    onUnauthorized: async (e: Error) => {
      if (e instanceof AccessDeniedInterrupt) {
        return "The user has deny the request";
      }
      return e.message;
    },
  });
```

auth0

© Okta, Inc. and/or its affiliates. All rights reserved.

DATA CLASSIFICATION: OKTA, INC. PUBLIC

Authorization in GenAI Applications

- LLMs don't enforce permissions, they generate responses from any data they receive
- Sensitive content can leak if document retrieval isn't properly filtered
- Without guardrails, RAG can expose private, regulated, or internal content
- RBAC is too coarse for RAG workflows
- Fine-grained, real-time authorization required for data retrieval

Common Security Risks

Misbehaving LLM Intentions
LLMs may retrieve or use data in ways they were not explicitly intended

External Access to Confidential Information
RAG systems can expose IP, private data or internal content to the wrong user or partner.

Impersonation via Hallucination
LLMs may fabricate actions or statements as if made by a specific user, without verifying identity or authorization.

Overexposure and no auditability
Agents may request and receive more access than necessary, and no clear audit trail is captured.

auth0 © Okta, Inc. and/or its affiliates. All rights reserved.

DATA CLASSIFICATION: OKTA, INC. PUBLIC

Authorization in GenAI Applications

Practical example

AI Agent can only access a patient's record if explicitly authorized

AI Agent must not modify medical records

AI Agent must not access records belonging to other patients

How do enforce that at runtime?

© Okta, Inc. and/or its affiliates. All rights reserved.
DATA CLASSIFICATION: OKTA, INC. PUBLIC

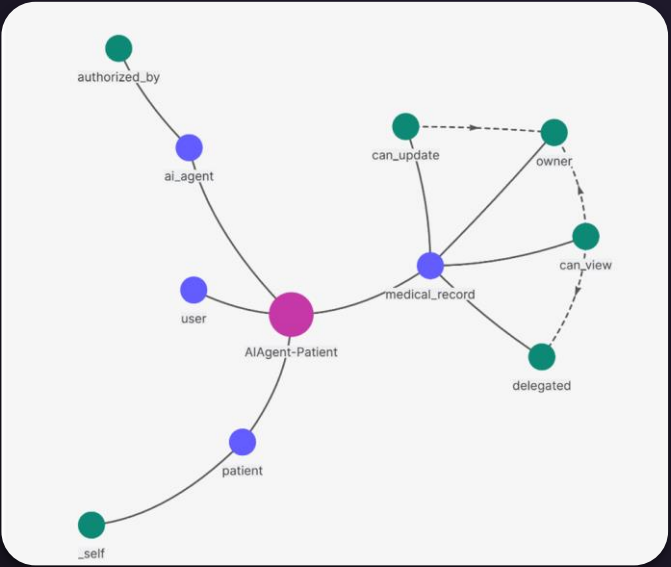
AuthO Fine-Grained Authorization (FGA)

Relationship-based Access Control (ReBAC)

Authorization Model

```
model
  schema 1.1

type user

type patient
  relations
    define _self: [user]

type ai_agent
  relations
    define authorized_by: [patient]

type medical_record
  relations
    define can_update: owner
    define can_view: owner or delegated
    define delegated: [ai_agent#authorized_by]
    define owner: [patient]
```

Relationship Graph



Permission Data (tuples)

USER	patient:john_doe
OBJECT	medical_record:mr_333
RELATION	owner

USER	patient:john_doe
OBJECT	ai_agent:ai_111
RELATION	authorized_by

USER	ai_agent:ai_111#authorized_by
OBJECT	medical_record:mr_333
RELATION	delegated

© Okta, Inc. and/or its affiliates. All rights reserved.

DATA CLASSIFICATION: OKTA, INC. PUBLIC

RAG Pipeline with Auth0 FGA

1. User Prompt

"Show my last appointment record"

2. Retrieve

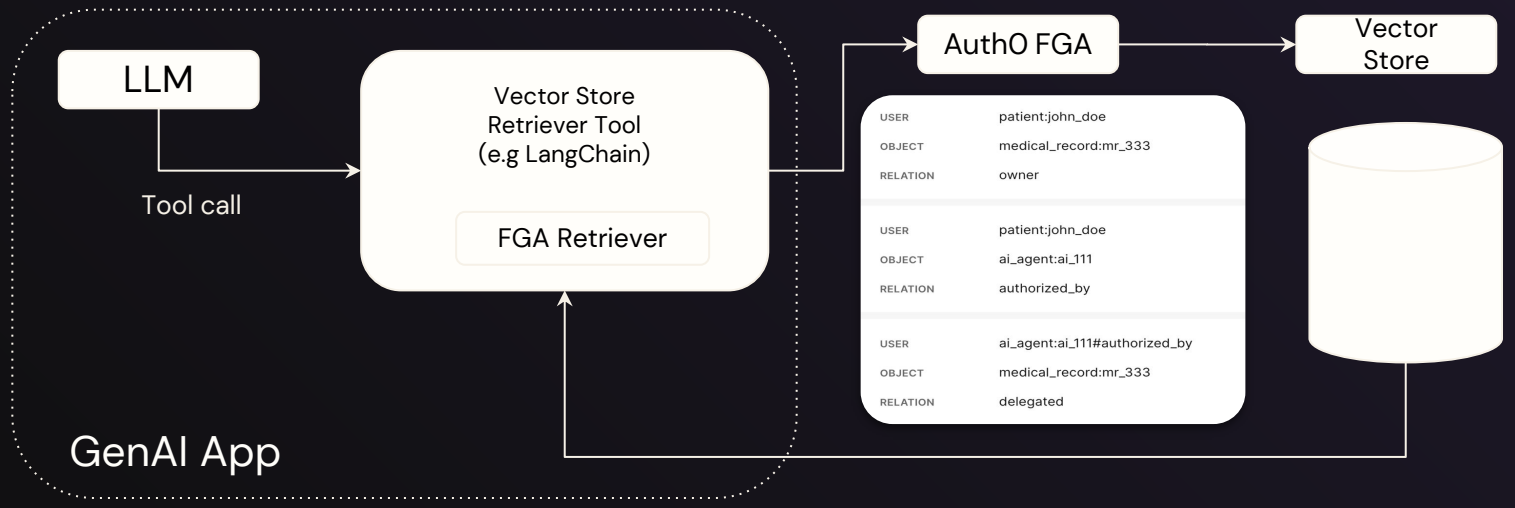
AI Agent retrieves relevant docs from vector store

3. Filter

FGA filter docs by user permission

4. Answer

Agent only sees what the user is allowed to access



Example: LangChain + FGA integration

```
const user = "user1";
// 1. Read and load documents from the assets folder
const documents = await readDocuments();
// 2. Create an in-memory vector store from the documents for OpenAI models.
const vectorStore = await MemoryVectorStore.fromDocuments(
  documents,
  new OpenAIEmbeddings({ model: "text-embedding-3-small" })
);
// 3. Create a retriever that uses FGA to gate fetching documents on permissions.
const retriever = FGARetriever.create({
  retriever: vectorStore.asRetriever(),
  // FGA tuple to query for the user's permissions
  buildQuery: (doc) => ({
    user: `user:${user}`,
    object: `doc:${doc.metadata.id}`,
    relation: "viewer",
  }),
});
// 4. Convert the retriever into a tool for an agent.
const fgaTool = retriever.asJoinedStringTool();
// 5. The agent will call the tool, rephrasing the original question and
// populating the "query" argument, until it can answer the user's question.
const retrievalAgent = RetrievalAgent.create([fgaTool]);
// 6. Query the retrieval agent with a prompt
const answer = await retrievalAgent.query("Show my last appointment record");
```

© Okta, Inc. and/or its affiliates. All rights reserved.

DATA CLASSIFICATION: OKTA, INC. PUBLIC

Everything you need to build AI agents securely

Authentication for GenAI

Token Vault

Asynchronous Authorization

Fine Grained Authorization for RAG

© Okta, Inc. and/or its affiliates. All rights reserved.

DATA CLASSIFICATION: OKTA, INC. PUBLIC

Get Started today with Auth0 for AI Agents

auth0

Docs | How-Tos | SDKs | Log in | Start building

AUTH FOR GENAI

GET STARTED
- User Authentication
- Call Your APIs on User's Behalf
- Call Other's APIs on User's Behalf
- Asynchronous Authorization
- Authorization for RAG

HOW-TOS
- Check Google Calendar Availability
- List GitHub Repositories
- List Slack Channels
- Get Salesforce Opportunities

SAMPLE APPS

SDKS
- JavaScript
- Python

GUIDES
- Google Sign-in and Authorization
- Client-Initiated Account Linking

CONCEPTS

SUPPORT & COMMUNITY

Get Started

Get Started

Start building with Auth for GenAI quickstarts.

User Authentication — NEXT.JS, FASTAPI
Leverage Auth0's Universal Login to enable AI agents to securely authenticate users.

Call Your APIs on User's Behalf — NEXT.JS, VERCEL AI
Manage tokens to enable AI agents to call first-party APIs.

Call Other's APIs on User's Behalf — NEXT.JS, VERCEL AI, FASTAPI
Connect AI agents to external tools, functions, and services. Auth0 handles token refreshes and exchanges without any user intervention.

Asynchronous Authorization — NODE.JS, VERCEL AI, LANGCHAIN
Add human-in-the-loop controls for critical or delayed actions using secure protocols like Client-Initiated Backchannel Authentication and Pushed Authorization Requests.

Authorization for RAG — NODE.JS, VERCEL AI, LANGCHAIN
Use Auth0 FGA to enforce document and relationship-level access control in your Retrieval Augmented Generation (RAG) pipelines.

PREVIOUS
« Auth for GenAI

NEXT
User Authentication »

Available now on
auth0.com/ai

Start your GenAI identity security journey with a Quickstart guide.

auth0 © Okta, Inc. and/or its affiliates. All rights reserved.

DATA CLASSIFICATION: OKTA, INC. PUBLIC

Thank you!

© Okta, Inc. and/or its affiliates. All rights reserved.

DATA CLASSIFICATION: OKTA, INC. PUBLIC

Q&A

© Okta, Inc. and/or its affiliates. All rights reserved.

DATA CLASSIFICATION: OKTA, INC. PUBLIC

Terminology

Generative AI (GenAI)
AI that produces new content (text, images, code) rather than just classifying data.

AI Agent
Autonomous system that plans and executes actions on behalf of users via APIs, tools, or workflows.

Async Authentication
Secure user approval flow that allows AI agents to initiate actions on behalf of users

Fine-Grained Authorization
Real-time authorization model defining object- and relationship-level access controls for agents.

Large Language Model (LLM)
Transformer-based model that generates coherent, context-rich text based on training data.

Prompt Engineering
Input prompts to guide LLM behavior toward specific goals or styles.

Retrieval-Augmented Generation (RAG)
AI that produces new content (text, images, code) rather than just classifying data.

Embedding
Numerical representation of semantic meaning, enabling similarity search and document retrieval.

© Okta, Inc. and/or its affiliates. All rights reserved.

DATA CLASSIFICATION: OKTA, INC. PUBLIC